TASK 1
Vulnerability Assessment Report

Prepared By:
Ali Mohammed Ahmed AlKhatib
Cyber Security Internship
Future Interns
Date: April 2026

Target Website:
https://demo.testfire.net

Methodology & Tools

This assessment was conducted using a read-only approach to ensure no disruption or unauthorized interaction with the target system. The analysis focused on identifying potential security weaknesses through passive observation techniques.

The following tools and methods were used:

- Browser Developer Tools – to inspect HTTP headers, cookies, and client-side issues
- Nmap – to identify exposed services and open ports
- OWASP ZAP (Passive Scanning)– to observe web traffic and identify common security misconfigurations without performing intrusive testing

All findings were documented and classified based on their potential risk level (Low, Medium, High), along with recommended remediation steps.

Exposed Services Analysis

An Nmap scan was performed on the target website to identify open ports and running services.

The scan revealed the following open ports:

- Port 80 (HTTP) – Standard web traffic (Apache Tomcat/Coyote JSP engine)
- Port 443 (HTTPS) – Secure web communication
- Port 8080 (HTTP-Proxy) – Alternate web service port

While ports 80 and 443 are expected for web applications, the presence of port 8080 indicates an additional exposed service. This may increase the attack surface if not properly secured. Additionally, the server response revealed the use of Apache Tomcat technology, which may expose information about the underlying system and assist attackers in identifying potential vulnerabilities.

Exposed services and technologies should be regularly monitored and properly secured to reduce the attack surface.

Finding 1: Open Port 8080

Issue: Port 8080 is open and accessible on the target system.
Risk Level: Medium
Why It Matters: Open ports can expose additional services that may be vulnerable to attacks. If not properly secured, attackers may exploit these services to gain unauthorized access.
Recommendation: If port 8080 is not required for business operations, it should be closed to reduce exposure. If it is needed, access should be restricted using firewall rules so that only authorized users or systems can connect to it.

```
C:\Users\3limo>nmap demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 16:04 +0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.23s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
8080/tcp open   http-proxy
8443/tcp closed https-alt

Nmap done: 1 IP address (1 host up) scanned in 14.85 seconds
```

Finding 2: Technology Disclosure (Apache Tomcat)

Issue: The server reveals its underlying technology: Apache Tomcat/Coyote JSP engine.

Risk Level: Medium

Why It Matters: Exposing server technologies allows attackers to identify potential vulnerabilities specific to that software. If the version is outdated or has known issues, it can be targeted more easily.

Recommendation: Hide or limit server information in HTTP headers and responses to reduce exposure of internal technologies.

```
C:\Users\3limo>nmap -sV demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 16:05 +0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.24s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE   VERSION
80/tcp   open   http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp  open   ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open   http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp closed https-alt

Service detection performed. Please report any incorrect results a
Nmap done: 1 IP address (1 host up) scanned in 33.10 seconds
```

Finding 3: Missing Security Headers

Issue: The application does not include important security headers such as Content-Security-Policy, X-Frame-Options, and Strict-Transport-Security.

Risk Level: Medium

Why It Matters: Security headers provide an additional layer of protection against common web attacks such as Cross-Site Scripting (XSS) and clickjacking. Without these headers, the application is more vulnerable to malicious scripts and unauthorized manipulation of user interactions.

Recommendation: The website should implement standard security headers to enhance protection. This includes configuring Content-Security-Policy, X-Frame-Options, and Strict-Transport-Security on the server to reduce exposure to common web-based attacks.

Headers | Preview | Response | Initiator | Timing | Cookies

▾ General

Request URL	https://demo.testfire.net/
Request Method	GET
Status Code	200 OK
Remote Address	65.61.137.117:443
Referrer Policy	strict-origin-when-cross-origin

▾ Response headers Raw

Content-Type	text/html;charset=ISO-8859-1
Date	Mon, 20 Apr 2026 12:07:36 GMT
Server	Apache-Coyote/1.1
Transfer-Encoding	chunked

▾ Request Headers Raw

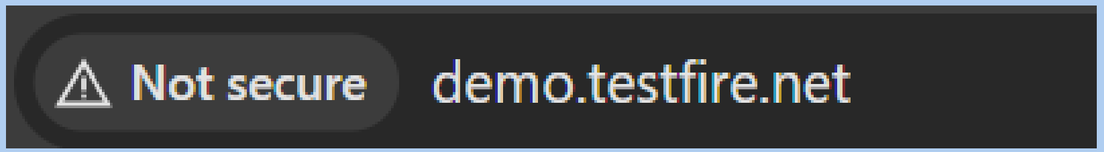
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding	gzip, deflate, br, zstd
Accept-Language	en-US,en;q=0.9
Cache-Control	max-age=0
Connection	keep-alive
Cookie	JSESSIONID=6885CFD11B1639D6405C1270E0D266DD
Host	demo.testfire.net
Sec-Ch-Ua	"Google Chrome";v="147", "Not.A/Brand";v="8", "Chromium";v="147"
Sec-Ch-Ua-Mobile	?0
Sec-Ch-Ua-Platform	"Windows"
Sec-Fetch-Dest	document
Sec-Fetch-Mode	navigate
Sec-Fetch-Site	none
Sec-Fetch-User	?1
Upgrade-Insecure-Requests	1
User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36

Content Security Policy (CSP) Header Not Set	Medium	10 (66.7%)
Missing Anti-clickjacking Header	Medium	10 (66.7%)

Server Leaks Version Information via "Server" HTTP Response Header Field	Low	10 (66.7%)
Strict-Transport-Security Header Not Set	Low	5 (33.3%)
X-Content-Type-Options Header Missing	Low	10 (66.7%)

Finding 4: No HTTPS Enforcement

Issue: The website allows access over HTTP without forcing HTTPS.
Risk Level: Medium
Why It Matters: Users may connect over an unencrypted connection, exposing data to interception.
Recommendation: Redirect all HTTP traffic to HTTPS and implement HSTS.



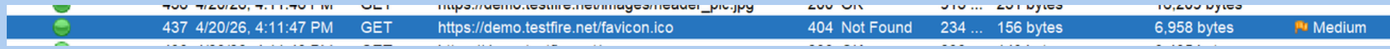
Finding 5: Improper resource handling

Issue: Some resources, such as favicon.ico, return a 404 Not Found response.

Risk Level: Low

Why It Matters: Missing or improperly handled resources may indicate weak configuration and can reveal information about the application structure.

Recommendation: Ensure all required resources are properly configured and accessible, or remove unnecessary references.



Conclusion

This vulnerability assessment identified several security weaknesses in the target web application, including exposed services and missing security configurations. While no critical vulnerabilities were found, the presence of unencrypted communication channels and information disclosure increases the potential attack surface.

Addressing these issues through proper configuration and security best practices will improve the overall security posture of the application. Regular monitoring and periodic security assessments are recommended to maintain a secure environment.